

Fig. 4: Problem of direct telnetting to the e-mail server and sending an e-mail

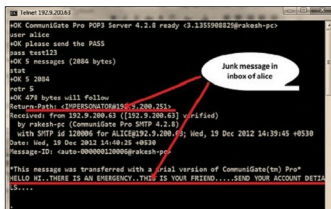


Fig. 5: Spoofed e-mail sent, being viewed

sense, even if read.

2. **Loss of integrity.** When an e-mail travels over a network, the body of the e-mail, which is the message part, can be altered in transit, resulting in the loss of integrity. This threat can be removed by creating a hash of the message at its origin and sending it along with the message. Hash of the message can be recalculated at the receiver's end and matched to find out if any change has been made in the message over the network by any intruder, and thus in a way takes care of the integrity of the message.

3. **Lack of data origin authentication.** This threat occurs when a person who appears to have sent the e-mail is actually not the person to have sent the e-mail. This can be due to telnetting the SMTP server directly, sharing the e-mail passwords. This threat can be solved by using the concept of public key certificate, with the usage of public key and private key pair, with public key certificate from a certification authority (CA). We should also not allow direct telnetting to the e-mail server and restrict the common password for

individual e-mail accounts.

Fig. 4 and Fig. 5 depict the problem of direct telnetting to the e-mail server and sending an e-mail, lacking data origin authentication. In Fig. 4, we are telnetting to an IP address (of the e-mail server) on port 25, which is the default port for SMTP. When writing mail from < >, we have written impersonator@ipaddress and sent to alice@ipaddress. Whilst retrieval of the

e-mail, as shown in Fig. 5, we have telnetted to an IP address (of the e-mail server) on port 110 for the same. When logging on to Alice's e-mail inbox, we see the mail to have arrived from impersonator@ipaddress. One important point to remember is that we have taken the example as impersonator@ipaddress. This address can be replaced with any other e-mail ID and can create lots of problems.

4. **Lack of non-repudiation.** This threat arises when the receiver cannot trust the contents sent. There is also mistrust that the sender can deny having sent the e-mail.

5. **Lack of notification of receipt.** Similar to the above situation, there is a threat in which the sender can have a mistrust whether the receiver has received the e-mail or not. The message which was marked as sent may not have been sent.

The last two threats can be removed by the usage of digital signatures. A digital signature is an electronic means of authenticating an online identity. Along with the authentication, it takes care of the

non-repudiation and ensures that an actual sender has sent the e-mail and the authentic receiver has received the e-mail. Digital signature is created when we encrypt the hash of the e-mail message with private key of the sender.

To add to this, we can make this scheme more powerful by encrypting the hash of the e-mail message with the private key of the sender and then again encrypting the result with the public key of the recipient. This ensures that only the receiver is able to read the e-mail and also makes it clear that only the sender has sent the e-mail. This scheme is also known as bidirectional hashing. A fully-secure e-mail can be sent by using the combination of hashing, encryption and digital signature. This scheme is shown in Fig. 6.

**Threats to an organisation that arise due to an e-mail.** These threats mainly include:

1. **Disclosure of sensitive information.** As we know, disclosure of information can be done quickly by e-mail compared to paper-based mail. The information can be quite sensitive/strategic or of proprietary nature. We do not want to get into the disclosure, whether the disclosure was deliberate (and malicious) or unintentional. Whatsoever it was, disclosure has happened. At the same time, we also have to take into account the fact that disclosure may be internal or external. By external we mean that an e-mail can cross the LAN limit into the Internet world. Such disclosures can lead to loss of information and can even cause loss of reputation of an organisation.

2. **Exposure of systems to malicious code.** E-mail is the main vector by which computer viruses spread. Self-replicating code embedded in e-mail exploits features/vulnerabilities of the e-mail client. Such vulnerabilities mainly include VBScript, JavaScript in HTML-formatted e-mail and exe attachments of dancing pigs.

3. **Exposure to denial of service attacks.** Denial of service (DoS) is an attack